

الأسرار والمفاتيح — أين يذهب كل واحد (المنتجان)

القسم operations-it-06 النوع document الحالة active المالك Founder آخر تحديث 19-08-2026

فهرس واحد لمكان ضبط كل سر ومفتاح وسعر عبر الخادمين. لا توجد أي قيمة سر هنا — أسماء ومواقع فقط. الخطوات التفصيلية في الـ runbooks الموثوقة (روابط في الأسفل): هذه الصفحة خريطة فوقها.

قواعد ذهبية

- لا تضع قيمة سر في git أو المصادقة أو الشيفرة. فالأسرار تعيش فقط في Google Secret Manager؛ وتقرأها الخدمة وقت التشغيل كمتغيرات بيئة محققة.
- متغيرات `VITE_*` قيم عامة وقت البناء تُرسل للمتصفح — ليست أسرارًا (المفاتيح المنشورة، عناوين المواقع، معرفات التحليلات). آمنة للكشف.
- الآبيان لا يغادر هذا المستودع (انظر `01-governance/company-facts.md`).
- لا يستخدم أي من المنتجين Firebase. فلم تعد هناك خطوة `firebase functions:secrets:set`، ولا ملف `functions/.env.*` — فكل شيء إعداد على مراجعة Cloud Run. انظر `hosting-facts.md`.

أ flygaca.com — ay2m/FlyGACA • خدمة Cloud Run • flygaca-api • الإقليم me- central2 (الدهام)

الأسرار ← Google Secret Manager، سر واحد لكل قيمة:

```
printf '%s' 'VALUE' | gcloud secrets create NAME --data-file=-
```

ثم تُحمّل على المراجعة عبر `gcloud run deploy --set-secrets=ENV_VAR=secret-name:latest`. امنح حساب خدمة Cloud Run الدور `roles/secretmanager.secretAccessor` (والدور `roles/cloudsql.client` لقاعدة البيانات).

متغير البيئة	الاسم في Secret Manager	ما هو / من أين	مطلوب
<code>DATABASE_URL</code>	<code>database-url</code>	عنوان مقبس unix الخاص بـ Cloud SQL — <code>postgresql://...@/flygaca?host=/cloudsql/PROJECT:REGION:INSTANCE</code>	الإقلاع ☒
<code>SESSION_SECRET</code>	<code>session-secret</code>	تولده أنت (<code>openssl rand -base64 48</code>) — يوقع رمز JWT للجلسة؛ 32 حرفًا على الأقل	الإقلاع ☒

متغيّر البيئة	الاسم في Secret Manager	ما هو / من أين	مطلوب
GOOGLE_OAUTH_CLIENT_SECRET	google-oauth-secret	GCP ← APIs & Services ← Credentials الويب	✓ الدخول بـ Google
GOOGLE_GENAI_API_KEY	genai-api-key	مفتاح Gemini — Google AI Studio (aistudio.google.com)	✓ المحادثة
MOYASAR_SECRET_KEY	moyasar-secret-key	لوحة Moyasar ← Developers ← API keys (sk_live_...)	✓ الفوترة
MOYASAR_WEBHOOK_SECRET	moyasar-webhook	السر المشترك لوييهوك Moyasar (يُتحقق من التوقيع على الجسم الخام)	○ خط دفاع احتياطي
MAIL_API_KEY	mail-api-key	مفتاح البريد المعاملاتي المتوافق مع Resend. وغيابه ⇒ تُسجّل الرسائل ولا تُرسل	○
CRON_SECRET	cron-secret	تولّده أنت (openssl rand -hex 32) — يحرس POST /api/billing/renew	✓ التجديدات

تعمل `assertRequiredConfig()` قبل ارتباط المستمع، فالمراجعة التي ينقصها `DATABASE_URL` — أو تحمل `SESSION_SECRET` أقصر من اللازم — تفشل في فحص سلامتها بدل أن ترجع خطأ 500 لاحقاً.

العمليات (ليست أسراراً) ← `gcloud run deploy --set-env-vars=... server/src/config.ts` هو الموضوع الوحيد الذي يقرأ فيه الخادم `process.env`:

- المصادر (مطلوبة): `API_ORIGIN=https://api.flygaca.com` , `APP_ORIGIN=https://flygaca.com` —
يجب أن يطابق `API_ORIGIN` عنوان تحويل OAuth مطابقة تامة وإلا فشل النداء الراجع بخطأ `redirect_uri_mismatch`. كما يبي `APP_ORIGIN` رابط رجوع Moyasar.
- ومطلوبة كذلك في حكم العادة: `MAIL_FROM` , `GOOGLE_OAUTH_CLIENT_ID` , `NODE_ENV=production`.
- الأسعار (أعداد صحيحة بالريال، بلا قيم افتراضية — وغياب أحدها يرمي خطأً عند السداد، ولا يفرض مبلغ 0 ريال صامتاً): `PRICE_CREDITS` , `PRICE_PASS` , `PRICE_PRO_ANNUAL` , `PRICE_PRO_MONTHLY` , `PRICE_PREP_PACK_COMPLETE` , `PRICE_PREP_PACK_STANDARD` , `PRICE_PREP_PACK_ESSENTIAL` , `PRICE_COHORT` , `PRICE_BUNDLE` (ويوجد كذلك `PRICE_PREP_PACK` بوصفه السعر العام للحزمة المفردة).
- ضبط اختياري: `CHAT_CREDIT_PACK_SIZE` , `ANON_DAILY_LIMIT` , `CHAT_FREE_DAILY_LIMIT` , `SESSION_TTL_DAYS` , `CORPUS_URL` , `GROUNDING_SCORE` , `REFUSE_SCORE` , `RETRIEVE_K` , `CHAT_ENABLED` , `EXTRA_ALLOWED_ORIGINS` , `DATABASE_POOL_MAX` , `SESSION_COOKIE_DOMAIN`.

عامة (ليست أسراراً) ← ملف `env.local`. الجذري، تُخز في بناء تطبيق الصفحة الواحدة كـ `VITE_*`:
`VITE_API_BASE_URL` (أو `VITE_API_SAME_ORIGIN=1` حين يقدّم موازن الأحمال الاثنان من مصدر واحد)،
`VITE_MOYASAR_PUBLISHABLE_KEY` (`pk_live_...`)، إضافةً إلى الاختيارية `VITE_DATA_BASE_URL`.

VITE_GA_MEASUREMENT_ID , VITE_SITE_URL

من دون VITE_API_BASE_URL يتجاهل التطبيق واجهة البرمجة كليًا ويعمل بنهج المحلي أولاً — فالمتن والأدوات والدراسة وسجل الطيران كلها تعمل؛ بينما تبقى الحسابات والمزامنة والفوترة معطلة. وهذا هو الوضع الافتراضي لـ CI ولبناء المعاينة، ولهذا لا تحتاج أي وظيفة CI إلى أسرار الإنتاج.

اعتمادات النشر / CI (إعدادات المستودع ← Secrets): اعتماد حساب خدمة GCP لأمر `gcloud run deploy` ومزامنة الحاوية (Workload Identity / GCP_SA_KEY) و `CLOUDFLARE_API_TOKEN` و `CLOUDFLARE_ACCOUNT_ID` لمرآة العامل. (ولا وجود لـ `FIREBASE_SERVICE_ACCOUNT` — فذلك الاعتماد كان يخص المستودع السلف المؤرشف).

ب) captadel.com — ay2m/Captain-Adel · Cloud Run · الإقليم me-central2 (الدمام)

الأسرار ← Google Secret Manager، عبر `gcloud secrets create NAME --data-` | `printf '%s' "VALUE"` : `export NAME=... .. && ./deploy/deploy.sh secrets` أو الاختصار الدفعي `file=-`

السر	ما هو / من أين	مطلوب
GEMINI_API_KEY	مفتاح Gemini — Google AI Studio (نفس مفتاح flygaca، باسم مختلف)	✓
MOYASAR_SECRET_KEY · MOYASAR_PUBLISHABLE_KEY · MOYASAR_WEBHOOK_SECRET	لوحة Moyasar	✓
MOYASAR_PRICE_MONTHLY_SAR (35) · MOYASAR_PRICE_ANNUAL_SAR (299)	تحددتها أنت	✓
CRON_SECRET	تولده (<code>openssl rand -hex 32</code>) — يحرس مسار التجديدات	✓
ADEL_API_KEY	سر مشترك تخترعه (طبقة API الموثوقة)	○
ALLAM_* , EMBEDDINGS_* , RERANK_*	مزود عربي داخل المملكة / استرجاع كثيف	○ لاحقًا

بيئة غير سرّية ← `set-env-vars --` في `deploy.sh` : `SITE_URL=https://captadel.com` , `MODEL_PROVIDER` , `ARABIC_PROVIDER` , `ADEL_LAUNCH_MODE` , `ADEL_DAILY_*`

ما يزال `deploy.sh` يعرض `REGION=me-central1` بديلًا احتياطيًا إن رفضت الدمام النشر. لا تأخذ به للإنتاج. فـ `me-central1` هي الدوحة، قطر — خارج المملكة — و `captadel` يعالج استعلامات مستخدمين حقيقية، وهي بيانات شخصية بموجب PDPL. وإن لم يكن `me-central2` متاحًا فصعد الأمر بدل النشر غربًا.

GitHub Actions : GCP_SA_KEY

خمس نقاط انتباه

1. مفتاح Gemini واحد باسمين — `GOOGLE_GENAI_API_KEY` (flygaca) مقابل `GEMINI_API_KEY` (captadel). نفس القيمة من Google AI Studio، تُضبط في مخزن كل منتج على حدة.

2. الأسعار مسقاة على نحو مختلف في كل منتج. يستخدم flygaca متغيرات `PRICE_*` المجردة (أعدادًا صحيحة بالريال) على مراجعة Cloud Run؛ بينما ما يزال captadel يستخدم `MOYASAR_PRICE_*_SAR`. أما أسماء `MOYASAR_PRICE_*_SAR` القديمة في flygaca — وكل مفتاح سعر يحمل `*_STUDENT_*` — فلم تعد موجودة؛ وإن وجدتها في وثيقة أو نص برمجي فهي متقادمة.
3. حساب Moyasar واحد، مخزنان + ويهوكان — اضبط مفاتيح Moyasar في المخزين، وسجل ويهوكين في لوحة Moyasar: `https://api.flygaca.com/api/billing/webhook/moyasar` . وفي flygaca يكون الويهوك دفاعًا في العمق — إذ يستدعي مسار الرجوع في المتصفح `POST /api/billing/confirm` ، الذي يجلب الدفعة من خادم إلى خادم؛ ويصّب الاثنان في الدالة `fulfil()` نفسها المحضنة ضد التكرار.
4. المفتاح المنشور — متغير بناء عام في flygaca (`VITE_MOYASAR_PUBLISHABLE_KEY`) ، لكنه سرّ مخزن في captadel (`MOYASAR_PUBLISHABLE_KEY`) ، يُخدم عبر `/v1/config` .
5. لا Stripe، ولا Firebase، ولا App Check. فأني ذكر لـ "Stripe" أو `firebase functions:secrets:set` أو `functions/.env.*` أو `ENFORCE_APP_CHECK` أو `ADEL_APPCHECK_MODE` في وثيقة أقدم فهو متقادم — فكلًا المنتجين على Moyasar، وأسرار flygaca مدخلات اعتيادية في Secret Manager محمّلة على مراجعة Cloud Run.

الخطوات التفصيلية الموثوقة

- flygaca.com: `FlyGACA/docs/RUNBOOK-deploy.md` (إعداد المشروع، مدخلات Secret Manager، سطر النشر `--set-secrets / --set-env-vars` ، ووظيفة التجديد في Cloud Scheduler) و `FlyGACA/docs/BILLING.md` (السداد ← التأكد ← الويهوك ← التجديد).
- `Captain-Adel/docs/RUNBOOK-captadel-saas.md` §3 captadel.com: (مفاتيح Moyasar، الويهوك، Apple Pay، التجديدات)، `docs/RUNBOOK-captadel-deploy.md` (Gemini + المشروع + النشر).